

République du Cameroun
Paix-Travail-Patrie

Ministère de l'Enseignement
Supérieur

Université de Garoua

Faculté des Sciences

Division des Affaires Académiques,
de la Sclolarité et de la Recherche



Republic of Cameroon
Peace-Work-Fatherland

Ministry of Higher Education

Université of Garoua

Faculté of Science

Division of Academic Affairs,
Student's Admission and Research

TRAVAUX PRATIQUES ENCADRÉS

UE : Supervision, Analyse Forensique et Gestion des incidents

Étudiant	NEYAMBE GONG
Matricule	
Niveau	Master II

Année Académique : 2025-2026

TRAVAIL PRATIQUE DU CHAPITRE 5-8

Exercice 5.1 — Strategie d'acquisition

Les 8 premieres actions dans l'ordre :

1. Ne rien alterer

Le systeme est allume (mode live) : toute action modifie la RAM. On documente l'etat visuel (ecran, connexions actives) avant toute intervention.

2. Documenter l'environnement physique

Photographier l'ecran, noter l'heure systeme, le nom de la machine, les peripheriques connectes. Debut de la chaine de custody.

3. Identifier et noter la connexion RDP suspecte

Avant toute capture, noter l'IP source, le compte utilise, l'heure — informations visibles et volatiles.

4. Capturer la RAM (acquisition live)

La RAM est la donnee la plus volatile (ordre RFC 3227). Utiliser WinPmem ou Magnet RAM Capture vers un support externe write-protege.

```
winpmem_mini_x64.exe /mnt/evidence/ram-erp01.raw
```

5. Capturer l'etat reseau et les processus (toujours live)

Avant d'eteindre, collecter les informations systeme :

```
netstat -ano > connexions.txt
```

```
tasklist /v > processus.txt
```

```
ipconfig /all > reseau.txt
```

6. Decision live/dead -> choisir dead pour le disque

La RAM est capturee. On eteint proprement (ou on arrache l'alimentation selon la politique) pour passer en mode dead afin d'obtenir une image disque integre.

7. Connecter un bloqueur en ecriture sur le disque

Brancher un write blocker materiel sur le disque avant toute connexion a la station forensique. Principe fondateur : ne rien alterer.

8. Calculer et noter le hash du disque source

Avant l'acquisition, hasher le disque original (SHA-256) pour prouver l'integrite initiale. Ce hash sera compare apres l'acquisition.

Exercice 5.2 — Commande d'acquisition avec dcfldd

Commande complete :

```
dcflddd if=/dev/sdc \  
  of=/mnt/evidence/erp-sdc.dd \  
  hash=sha256 \  
  hashlog=/mnt/evidence/erp-sdc.sha256.log \  
  bs=128K \  
  hashwindow=128K \  
  status=on
```

Commande de verification d'integrite :

```
sha256sum /mnt/evidence/erp-sdc.dd > /mnt/evidence/erp-sdc-verify.sha256  
diff /mnt/evidence/erp-sdc.sha256.log /mnt/evidence/erp-sdc-verify.sha256
```

Resultat : Si diff ne retourne rien -> hashes identiques -> integrite confirmee.

Exercice 5.3 — Procès-Verbal de saisie (chaîne de custody)

PROCES-VERBAL DE COLLECTE NUMERIQUE

Date : 08/05/2026

Nom / Prenom : NEYAMBE GONG

Qualite : Analyste forensique

Nom machine :srv-erp-01

Système d'exploitation : Windows Server 2022

Etat au moment de la saisie : ALLUME — Connexion RDP suspecte active

Bloqueur en écriture :

Support de destination : /mnt/evidence — Disque externe SSD, S/N

Outil d'acquisition : dcfldd

Outil utilise : WinPmem

Fichier produit : ram-erp01.raw

Source : /dev/sdc

Fichier image produit : erp-sdc.dd

Format : RAW (dd)

Taille des blocs : 128K

Exercice 6.1 — Analyse du registre Windows (RegRipper)

```
# Monter l'image en lecture seule
sudo mount -o ro,loop,offset=$((512*2048)) srv-erp-01.dd /mnt/image

# Copier les ruches vers le dossier de travail
cp /mnt/image/Windows/System32/config/SYSTEM ./ruches/
cp /mnt/image/Windows/System32/config/SOFTWARE ./ruches/
cp /mnt/image/Windows/System32/config/SAM ./ruches/
cp /mnt/image/Users/*/NTUSER.DAT ./ruches/
```

(a) Cles Run — Programmes au démarrage

Commandes RegRipper :

```
rip.pl -r ruches/SOFTWARE -p run
```

```
rip.pl -r ruches/NTUSER.DAT -p run
```

Cles de registre à documenter :

Cle de registre (chemin complet)	Nom valeur	Donnée / Executable	Commentaire
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run	WindowsDefender	C:\ProgramData\svc.exe	Suspect — nom trompeur
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnce	(exemple)	cmd.exe /c ...	A vérifier
HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run	OneDrive	C:\Users\...\OneDrive.exe	Legitime

(b) Comptes locaux dans la SAM
Commande RegRipper :
rip.pl -r ruches/SAM -p samparse

Compte	RID	Statut	Derniere connexion	Cle SAM complete
Administrator	500	Actif	2026-04-12 03:47:22	HKLM\SAM\SAM\Domains\Account\Users\000001F4
Guest	501	Desactive	Jamais	HKLM\SAM\SAM\Domains\Account\Users\000001F5
svc_backup	1001	Actif	2026-04-12 03:12:05	HKLM\SAM\SAM\Domains\Account\Users\000003E9
john.admin	1002	Actif	2026-04-11 22:30:11	HKLM\SAM\SAM\Domains\Account\Users\000003EA

(c) Fuseau horaire configure
Commande RegRipper :
rip.pl -r ruches/SYSTEM -p timezone

Champ	Valeur
Cle de registre	HKLM\SYSTEM\CurrentControlSet\Control\TimeZoneInformation
Valeur TimeZoneKeyName	Romance Standard Time (Paris UTC+1 / UTC+2 DST)
Valeur ActiveTimeBias	-60 (en minutes, = UTC+1)
Importance forensique	Tous les horodatages NTFS sont en UTC — convertir selon ce fuseau pour la timeline

Exercice 6.2 — Timeline NTFS avec fls et mactime

Etape 1 — Generer la timeline complete
1. Extraire les metadonnees NTFS (body file)
fls -r -m C: -o 2048 srv-web-01.dd > body_file.txt

2. Generer la timeline sur la plage horaire
mactime -b body_file.txt -d \
-z UTC \
2026-04-12T02:00:00 2026-04-12T06:00:00 \
> timeline_web01.csv

5 Evenements les plus suspects — avec TTPs MITRE ATT&CK

Heure UTC	Fichier / Chemin	Action (MAC)	TTP MITRE	Justification
2026-04-12 02:14:33	C:\Windows\System32\svchost_update.exe	Creation (m+b)	T1036.004 – Masquerading	Nom imitant un process systeme legitime, cree en pleine nuit
2026-04-12 02:47:11	C:\Users\svc_backup\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\run.vbs	Creation (m+b)	T1547.001 – Boot/Logon Autostart	VBScript dans dossier Startup = persistance au redemarrage

2026-04-12 03:12:05	C:\Windows\Temp\mimikatz.exe	Creation + exec (m+a+b)	T1003.001 – LSASS Memory Dump	Nom d'outil de dump de credentials connu
2026-04-12 03:47:22	C:\Users\Administrator\Documents\dump.txt	Creation (m+b)	T1078 – Valid Accounts	Fichier cree par compte Admin apres connexion suspecte (cf. SAM)
2026-04-12 04:22:58	C:\Windows\System32\config\SAM	Acces (a)	T1003.002 – SAM Database	Acces direct a la base SAM = tentative d'extraction des hashes

Annotation dans le rapport

Pour chaque evenement, documenter :

Horodatage exact UTC + conversion heure locale

Chemin complet du fichier avec inode MFT

Type de changement MAC observe

TTP MITRE ATT&CK avec identifiant et nom

Justification forensique de la suspicion

Exercice 6.3 — Detection de persistance Linux

```
sudo mount -o ro,loop,offset=$((512*2048)) linux.dd /mnt/linux
export ROOT=/mnt/linux
```

1. Cron — Taches planifiees

Commandes d'investigation :

```
# Crontabs systeme
cat $ROOT/etc/crontab
ls -la $ROOT/etc/cron.d/
ls -la $ROOT/etc/cron.{hourly,daily,weekly,monthly}/
```

```
# Crontabs utilisateurs
ls -la $ROOT/var/spool/cron/crontabs/
cat $ROOT/var/spool/cron/crontabs/root
```

2. Systemd — Services et timers

Commandes d'investigation :

```
# Services systeme
ls -la $ROOT/etc/systemd/system/
ls -la $ROOT/lib/systemd/system/
cat $ROOT/etc/systemd/system/*.service
```

```
# Timers
ls -la $ROOT/etc/systemd/system/*.timer
```

```
# Services actives (sur systeme live)
systemctl list-units --state=enabled --type=service
```

3. LD_PRELOAD — Injection de bibliotheque

Commandes d'investigation :

```
# Fichier de configuration global
cat $ROOT/etc/ld.so.preload
```

```
# Variables d'environnement persistantes
grep -r 'LD_PRELOAD' $ROOT/etc/environment
grep -r 'LD_PRELOAD' $ROOT/etc/profile $ROOT/etc/profile.d/
```

```
grep -r 'LD_PRELOAD' $ROOT/home/*/.bashrc $ROOT/root/.bashrc
```

4. Authorized_keys — Acces SSH sans mot de passe

Commandes d'investigation :

```
# Toutes les clees SSH autorisees
find $ROOT/home $ROOT/root -name 'authorized_keys' 2>/dev/null
cat $ROOT/root/.ssh/authorized_keys
cat $ROOT/home/*/.ssh/authorized_keys
```

```
# Verifier les permissions (doivent etre 600)
stat $ROOT/root/.ssh/authorized_keys
```

5. Bashrc / Profile — Execution au login

Commandes d'investigation :

```
# Fichiers de configuration shell
cat $ROOT/root/.bashrc
cat $ROOT/root/.bash_profile
cat $ROOT/home/*/.bashrc
cat $ROOT/etc/bash.bashrc
cat $ROOT/etc/profile
ls $ROOT/etc/profile.d/
```

Exercice 7.1 — Analyse memoire avec Volatility 3

(a) Lister les processus actifs

```
# Liste arborescente parent/enfant
vol -f ram-srv-web-01.raw windows.pstree

# Liste simple avec PID, PPID, heure de demarrage
vol -f ram-srv-web-01.raw windows.pslist

# Version qui cherche aussi les processus caches
vol -f ram-srv-web-01.raw windows.psscan
```

Signaux suspects a reperer :

Signal suspect	Exemple	Raison
Nom trompeur	svchost.exe lance par explorer.exe	Normalement lance par services.exe
Process sans chemin disque	PID sans image associee	Malware injecte en memoire
Heure de demarrage anormale	Process lance a 02:14 UTC	Coincide avec l'intrusion
PPID incoherent	cmd.exe enfant de winword.exe	Exploitation de document Office

(b) Identifier les connexions reseau

```
# Connexions actives ET fermees (avec PID associe)
vol -f ram-srv-web-01.raw windows.netstat

# Connexions reseau avec port et etat
vol -f ram-srv-web-01.raw windows.netscan
```

Ce qu'on documente pour chaque connexion :

IP distante + port -> rechercher si IP connue comme C2 dans les bases Threat Intel

PID associe -> quel processus a etabli la connexion ?
Etat -> ESTABLISHED (actif), CLOSE_WAIT (termine recemment)
Port inhabituel -> ex: 443 vers une IP inconnue = HTTPS C2 possible

(c) Executer malfind — Zones memoire suspectes

```
vol -f ram-srv-web-01.raw windows.malfind
```

Ce que fait malfind : il cherche des regions memoire avec les permissions PAGE_EXECUTE_READWRITE (RWX) qui contiennent du code — caracteristique d'une injection de code ou d'un shellcode.

PID + nom du process	Identifier le processus infecte
Adresse memoire	Zone suspecte dans l'espace d'adressage
Permissions RWX	Execute + Ecrit + Lit = tres suspect pour une zone data
Octets MZ en tete	Signature d'un executable Windows (PE) injecte en memoire

```
# Extraire le binaire injecte pour analyse
vol -f ram-srv-web-01.raw windows.malfind --dump

# Chercher des chaines suspectes dans le dump
strings pid.xxx.dmp | grep -E "(http|cmd|powershell|beacon)"
```

(d) Detecter un processus cache — DKOM

Le DKOM (Direct Kernel Object Manipulation) est une technique rootkit : l'attaquant retire le processus de la liste officielle du kernel (EPROCESS) pour le rendre invisible a tasklist et au gestionnaire de taches.

```
# Comparer pslist (liste officielle) vs psscan (scan brut RAM)
vol -f ram-srv-web-01.raw windows.pslist > pslist.txt
vol -f ram-srv-web-01.raw windows.psscan > psscan.txt

# Tout PID present dans psscan mais ABSENT de pslist = cache par DKOM
diff pslist.txt psscan.txt
```

Exercice 7.2 — Analyse reseau (Wireshark + Zeek)

Fichier source : capture-incident.pcap | Outils : Zeek (logs automatiques) + Wireshark (analyse manuelle)

(a) Identifier l'IP de commande et controle (C2)

Avec Zeek — analyse automatique des connexions :

```
zeek -r capture-incident.pcap
cat conn.log | zeek-cut id.orig_h id.resp_h id.resp_p duration orig_bytes
```

Avec Wireshark — filtres manuels :

```
# Connexions TCP sortantes hors reseau local
tcp.flags.syn == 1 && !ip.dst == 192.168.0.0/16

# Requetes POST suspectes (upload / exfiltration)
http.request.method == "POST"
```

Indicateurs d'une IP C2 :

Connexion longue duree et reguliere = beacon (check-in toutes les X secondes)
Volume de donnees sortant > entrant = exfiltration
IP sans reputation ou dans une liste C2 connue (Threat Intel : VirusTotal, Shodan)

(b) Identifier le protocole de communication

```
# Zeek genere automatiquement les logs par protocole
cat http.log      # Trafic HTTP en clair
cat ssl.log       # Trafic TLS/HTTPS chiffre
cat dns.log       # Requetes DNS (DNS tunneling possible)
```

Protocoles C2 courants a chercher :

Protocole	Signe suspect	TTP MITRE
HTTP/S	POST reguliers vers meme IP, User-Agent bizarre	T1071.001
DNS	Requetes vers sous-domaines longs et aleatoires	T1071.004
ICMP	Donnees dans le payload des pings	T1095
Reverse shell	Connexion TCP sortante vers port 4444/1337	T1059

(c) Identifier les donnees exfiltrees

```
# Zeek - volume de donnees par connexion (trier par octets sortants)
cat conn.log | zeek-cut id.resp_h orig_bytes resp_bytes | sort -k3 -nr | head -20

# Chercher des donnees encodees en base64 dans les URI HTTP
cat http.log | zeek-cut uri | grep -E "[A-Za-z0-9+/{50,}={0,2}"

# Wireshark : clic droit sur paquet suspect -> Follow TCP Stream
```

Ce qu'on documente :

Volume total exfiltre en octets

Type de donnees (fichiers, credentials, captures ecran)

Encodage utilise (base64, XOR, chiffrement custom)

(d) Duree totale de l'activite C2

```
# Premier contact avec l'IP C2
cat conn.log | zeek-cut ts id.resp_h duration | grep 'IP_C2' | sort -k1 | head -1

# Dernier contact avec l'IP C2
cat conn.log | zeek-cut ts id.resp_h duration | grep 'IP_C2' | sort -k1 | tail -1
```

Heure de debut UTC	Premier paquet vers l'IP C2
Heure de fin UTC	Dernier paquet vers l'IP C2
Duree totale	Fin - Debut (peut etre plusieurs heures)
Sessions distinctes	Nombre de connexions TCP independantes vers le C2

Exercice 7.3 — CloudTrail : CreateAccessKey depuis IP TOR

Les 4 actions d'investigation dans l'ordre

Action 1 — Desactiver immédiatement la cle creee (Confinement)

C'est le principe de confinement : couper l'accès avant toute analyse pour limiter les dégats. La cle reste tracee dans les logs mais ne peut plus etre utilisee.

```
aws iam delete-access-key \  
  --access-key-id AKIA[ID_DE_LA_CLE_CREEE] \  
  --user-name LiZbiZ-SIS
```

Action 2 — Comprendre comment l'accès a ete possible

Chercher l'événement exact dans CloudTrail pour identifier la session d'origine, les permissions utilisees, et si un role a ete assume (AssumeRole).

```
aws cloudtrail lookup-events \  
  --lookup-attributes AttributeKey=EventName,AttributeValue=CreateAccessKey \  
  --start-time 2026-04-12T03:00:00Z \  
  --end-time 2026-04-12T04:00:00Z
```

Action 3 — Recenser toutes les actions effectuees

Chercher ce que l'attaquant a fait avec la cle : a-t-il cree d'autres backdoors ? Accede a S3 ? Lance des instances EC2 ? Modifie des politiques IAM ?

```
aws cloudtrail lookup-events \  
  --lookup-attributes AttributeKey=Username,AttributeValue=LiZbiZ-SIS \  
  --start-time 2026-04-11T00:00:00Z \  
  --end-time 2026-04-12T23:59:59Z
```

Action 4 — Auditer tous les accès IAM du compte AWS

Verifier si d'autres comptes ont ete compromis ou si des permissions ont ete escaladees. Generer le rapport de credentials complet.

```
# Rapport complet de toutes les cles et leurs dates d'utilisation
```

```
aws iam generate-credential-report  
aws iam get-credential-report
```

```
# Lister tous les utilisateurs et leurs cles actives
```

```
aws iam list-users  
aws iam list-access-keys --user-name LiZbiZ-SIS
```

Les logs CloudTrail a consulter

Log / Service AWS	Ce qu'on cherche
CloudTrail (principal)	CreateAccessKey, ConsoleLogin, AssumeRole, PutUserPolicy
IAM Access Advisor	Quels services ont ete accedes avec les nouvelles permissions
S3 Access Logs	Telechargement ou copie de donnees depuis les buckets
EC2 / CloudWatch	Lancement d'instances, modifications de security groups
GuardDuty	Alertes automatiques sur comportements anormaux (si active)
VPC Flow Logs	Connexions reseau depuis/vers les ressources AWS

Exercice 8.1 — Playbook Ransomware LiZbiZ-SIS (6 etapes)

Declencheur	Alerte SIEM : chiffrement massif de fichiers (extensions modifiees, CPU eleve, acces disque anormal) OU signalement utilisateur : fichiers inaccessibles + note de rançon.
-------------	--

1	Qualification (N1, < 15 min)
---	------------------------------

- Verifier l'alerte SIEM : quel endpoint ? quel compte ? depuis quand ?
- Confirmer la presence d'une note de rançon (README.txt, DECRYPT_FILES.html)
- Identifier les partages reseau touches (lecteurs mappes chiffres = propagation)
- Si faux positif (chiffrement legitime, backup) : fermer le ticket, documenter
- Si ransomware confirme : escalader N2, ouvrir le log d'incident, alerter le RSSI

2	Confinement immediat (N2, < 30 min)
---	-------------------------------------

Isoler reseau : debrancher le cable Ethernet ou bloquer le port switch (pas d'extinction)
Desactiver le compte compromis dans l'AD
Bloquer l'IP C2 identifiee au firewall pfSense
Isoler dans un VLAN de quarantaine les machines adjacentes potentiellement touchees
Capturer la RAM avant tout arret (WinPmem / avml) — cherche la cle de chiffrement

```
# Capture RAM Windows
winpmem_mini_x64.exe /mnt/evidence/ram-srv.raw
```

```
# Capture RAM Linux
avml /mnt/evidence/ram-srv.raw
```

3	Investigation (N2/N3, < 4 h)
---	------------------------------

Identifier le vecteur d'entree : phishing, RDP expose, vuln web ?
Analyser les logs d'authentification : premier compte compromis, heure d'entree
Analyser la timeline Sysmon / MFT : quand le chiffrement a-t-il commence ?
Identifier le variant de ransomware (ID Ransomware, extensions, note de rançon)
Cartographier les systemes touches : quels partages ? quels serveurs ?
Chercher les mecanismes de persistance (cles Run, taches planifiees, nouveaux comptes)

Outils : Volatility (RAM), FTK Imager (image disque), Sysmon, Wireshark (trafic C2)

4	Eradication (N2/N3)
---	---------------------

Supprimer les artefacts malveillants identifies (executable ransomware, scripts de deploiement)
Reinitialiser tous les credentials compromis : comptes AD, cles SSH, secrets AWS
Patcher la vulnerabilite exploitee (RDP, VPN, CVE identifiee)
Nettoyer les cles Run / taches planifiees malveillantes
Scanner tous les systemes du reseau avec un antivirus a jour

5

Retablissement (N2, < 72 h)

Restaurer depuis le dernier backup sain anterieur a la compromission
 Verifier l'integrite des sauvegardes avant restauration (hash SHA-256)
 Remettre en production progressivement : d'abord les services critiques
 Renforcer la surveillance : nouvelle regle SIEM ciblee sur le variant identifie
 Activer la journalisation etendue sur les systemes retablis

Date du backup sain = date pivot. Tout ce qui est posterieur est suspect.

6

Notification & RETEX (< 72 h)

Notifier la direction : impact metier, donnees touchees, mesures prises
 Evaluer l'obligation RGPD : si donnees personnelles chiffrees/exfiltrees -> notification CNIL sous 72 h
 Notifier l'ANSSI/ANTIC si OIV/OSE ou si attaque coordonnee
 RETEX dans les 72 h : chronologie, vecteur, impact financier, recommandations
 Mettre a jour le playbook avec les leçons apprises

Matrice d'escalade

Niveau	Role	Declencheur	Delai max
N1	Analyste SOC	Detection alerte SIEM	< 15 min
N2	Responsable SOC / RSSI	Incident confirme	< 30 min
N3	Forensic expert / DG	Compromission critique	< 4 h
Externe	ANSSI / Avocat / Assurance cyber	Selon gravite et obligations legales	Selon gravite

Exercice 8.2 — Classification de l'incident

Contexte

A 02h30, Wazuh alerte : modification de /etc/passwd sur srv-web-01 par le compte www-data.

Classification et justification

Champ	Valeur
Type d'incident	Compromission de compte / Elevation de privileges
Criticite	CRITIQUE (P1)
Categorie MITRE	T1098 — Account Manipulation
TTP secondaire	T1505.003 — Web Shell (vecteur probable)

CRITICITE : CRITIQUE — P1

Justification element par element

Element	Analyse forensique
Compte www-data	Compte de service Apache — n'a JAMAIS de raison legitime de modifier /etc/passwd
Heure 02h30	Heure non ouverte — activite anormale, probablement automatisee par un script
Fichier /etc/passwd	Fichier systeme critique — modification = ajout de compte backdoor ou escalade root
Serveur srv-web-01	Serveur web expose = vecteur d'entree probable (webshell, RCE via vuln applicative)

Conclusion : un attaquant a exploite une vulnerabilite web (RCE) pour executer du code sous www-data, puis a modifie /etc/passwd pour creer un backdoor ou s'elever en root.

Les 5 premieres actions a mener

Action 1 — Isoler srv-web-01 dans un VLAN de quarantaine

Couper la propagation immediatement sans eteindre la machine (preservation de la RAM).

Action 2 — Capturer la RAM

```
avml /mnt/evidence/ram-srv-web-01.raw
```

Action 3 — Examiner /etc/passwd et /etc/shadow

```
# Comparer avec un backup sain
diff /etc/passwd /backup/etc/passwd
```

```
# Chercher les comptes avec UID 0 (root)
awk -F: '($3 == 0)' /etc/passwd
```

```
# Voir les dernieres lignes ajoutees
tail -5 /etc/passwd
```

Action 4 — Analyser les logs Apache et auth.log

```
# Chercher le webshell ou la RCE dans les logs Apache
grep "www-data" /var/log/apache2/access.log | grep -E "(POST|cmd|exec|shell)"
```

```
# Authentifications suspectes autour de 02h30
grep "02:2[0-9]" /var/log/auth.log
```

Action 5 — Identifier la persistance installee

```
# Nouveaux comptes crees
grep "useradd\|adduser" /var/log/auth.log
```

```
# Crontabs de tous les utilisateurs
cat /var/spool/cron/crontabs/*
```

```
# Cles SSH ajoutees
find /home /root -name 'authorized_keys'
```

Exercice 8.3 — Resume executif (Directeur General)

1. Nature de l'incident

Dans la nuit du 11 au 12 avril 2026, LiZbiZ-SIS a ete victime d'une intrusion informatique ciblee. Un individu malveillant a penetre nos systemes en exploitant une faille sur notre serveur web, puis a etendu son acces a notre infrastructure cloud AWS.

Debut de l'intrusion : vers 22h30 le 11/04/2026

Detection : 02h30 le 12/04/2026

Fenetre d'exposition : environ 4 heures sans detection

2. Impact

Dimension	Detail
Systemes touches	Serveur web srv-web-01 + Compte AWS dev LiZbiZ-SIS
Donnees exposees	Donnees applicatives web ; acces API AWS cree frauduleusement
Disponibilite	srv-web-01 isole preventivement a 02h45 — interruption partielle
Cout estime	48-72h intervention technique + risque reglementaire RGPD si donnees personnelles exposees
Risque residuel	Verification en cours de l'etendue exacte des donnees accedees via la cle AWS

3. Mesures prises

N°	Action	Heure
1	Isolation immediate du serveur compromis dans VLAN quarantaine	02h45
2	Desactivation de la cle AWS creee frauduleusement	03h30
3	Capture forensique de la memoire RAM et des disques	03h00
4	Blocage de l'IP attaquante au pare-feu	02h50
5	Analyse forensique en cours pour determiner l'etendue	En cours
6	Renforcement des regles de surveillance SIEM	04h15

4. Recommandations

Priorite	Recommandation	Delai
CRITIQUE	Patcher la vulnerabilite web exploitee (CVE en cours d'identification)	Immediate
HAUTE	Activer l'authentification multi-facteurs sur tous les acces AWS et VPN	< 48h
HAUTE	Evaluer l'obligation de notification a la CNIL (donnees personnelles exposees ?)	< 72h
MOYENNE	Revue mensuelle des comptes et acces privileges (IAM, AD)	< 30 jours
MOYENNE	Audit de securite complet de l'infrastructure web exposee	< 30 jours

Prochaine étape : Presentation du rapport forensique complet sous 72 heures.
Responsable incident : RSSI | Contact : rssi@lizbiz-sis.fr